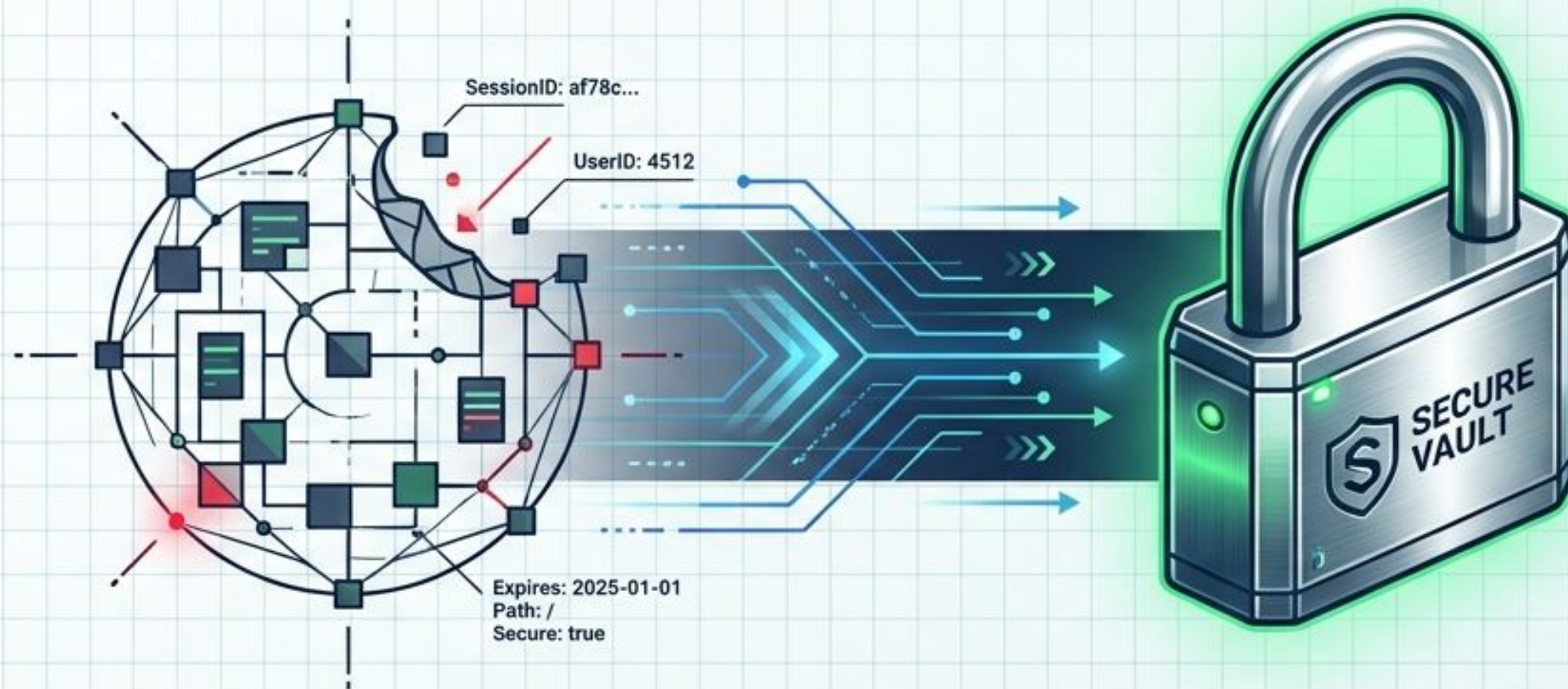




Muito Além do Navegador: A Arquitetura Segura de Cookies

Fundamentos, Ameaças e a Implementação do Padrão HttpOnly no Nosso Sistema

HTTP é Amnésico



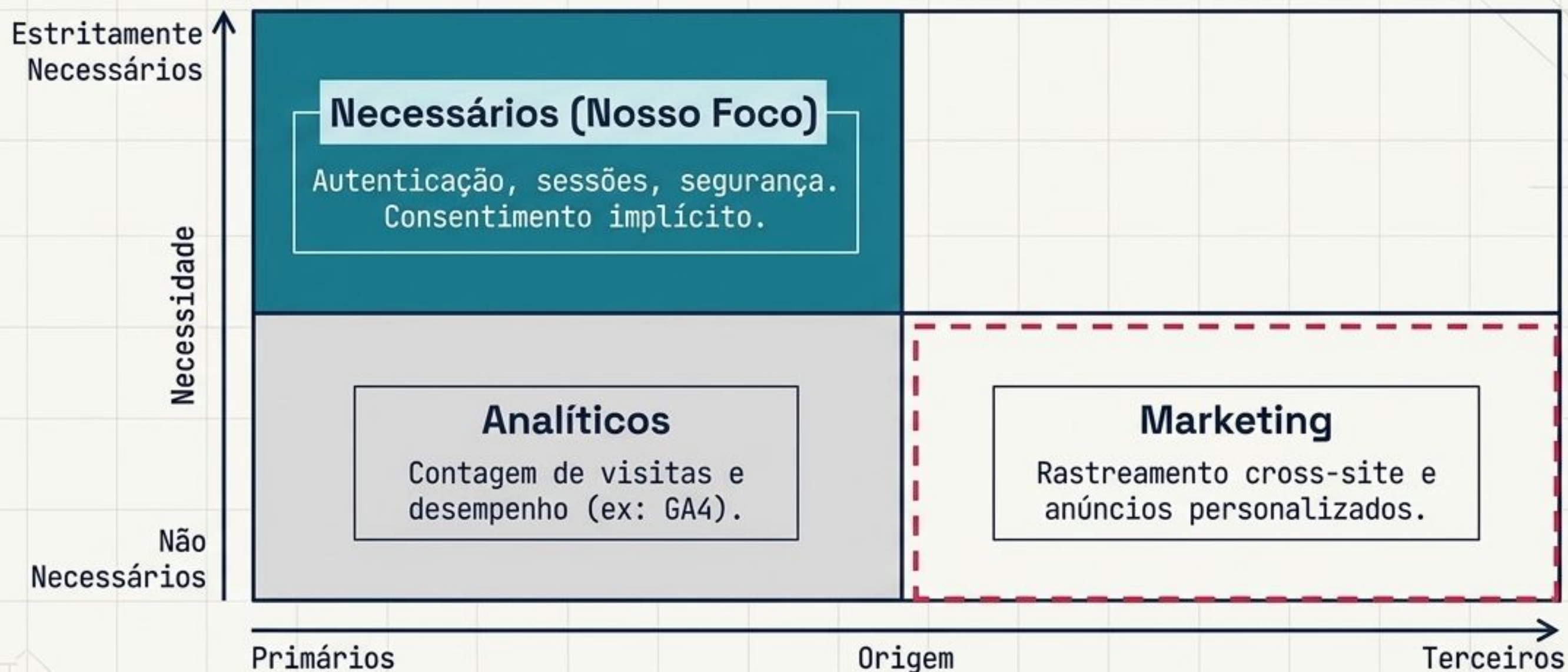
Sem estado (Stateless). O servidor esquece o usuário a cada novo clique.

O Cookie é a Memória



Criados em 1994, os cookies HTTP permitem que pacotes de dados transitem entre requisições, tornando viáveis sessões de login seguras.

Anatomia e Classificação (Contexto LGPD)



Takeaway Estratégico: Privacidade por Design. Nosso sistema foca em Cookies Primários Estritamente Necessários (Autenticação), garantindo conformidade natural com a LGPD.

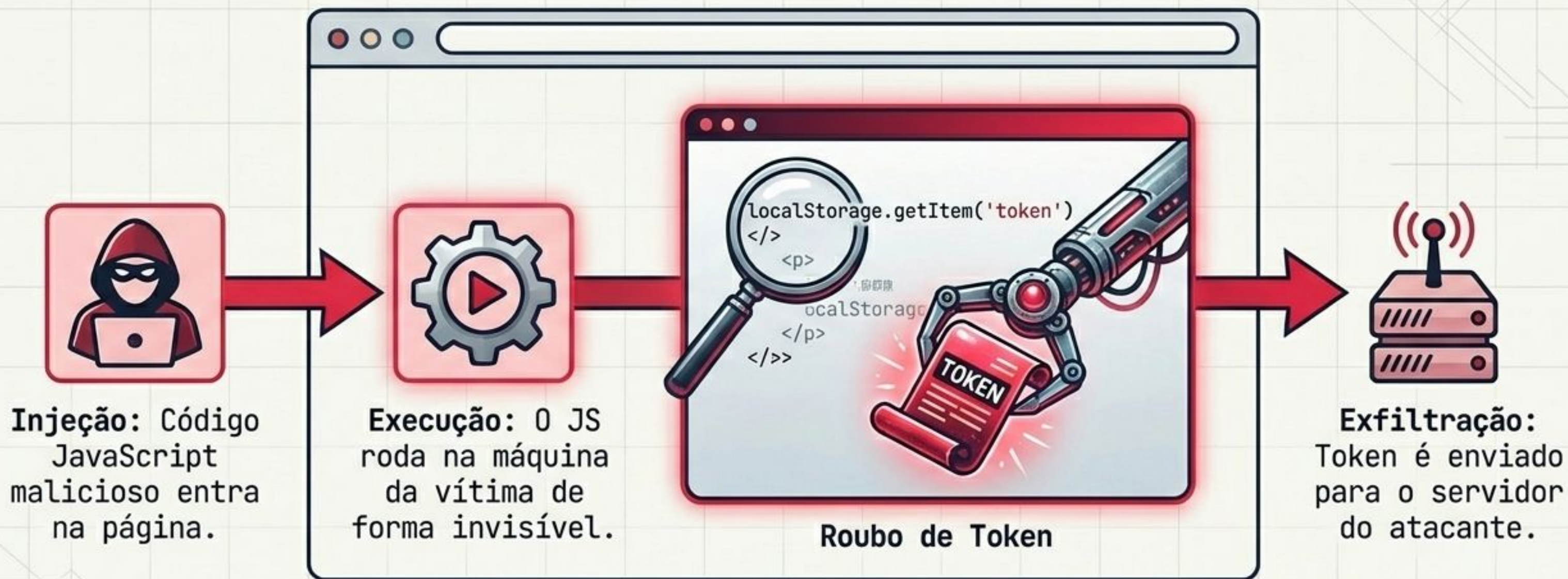
O Grande Debate: Cookies vs. Tokens

Dimensão	Cookies Tradicionais	Tokens JWT
Gestão de Estado	Servidor (Stateful)	Cliente (Stateless)
Escalabilidade	Baixa (Exige banco de dados)	Alta (Autocontido)
Vetor de Ameaça	Falsificação (CSRF)	Injeção (XSS)

[Agilidade do JWT] + [Segurança do Cookie] = A Nova Arquitetura

A melhor abordagem para o nosso sistema não é escolher um lado, mas guardar o nosso JWT (Token) dentro de um Cookie Seguro gerenciado pelo navegador.

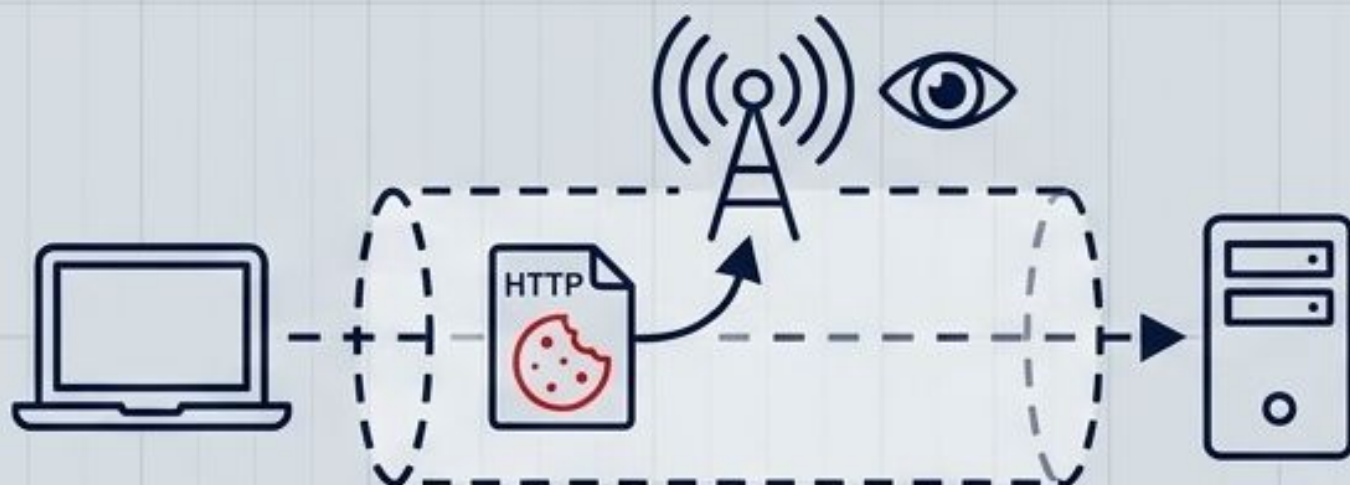
A Ameaça Silenciosa: XSS e o LocalStorage



Atenção: Se o token está no `localStorage`, QUALQUER script na página pode lê-lo. O usuário é sequestrado silenciosamente (Session Hijacking).

Ameaças de Rede: Interceptação e CSRF

A Ataque Man-in-the-Middle (MitM)



Sem tráfego blindado, cookies de autenticação são capturados em texto puro durante o trânsito.

B Falsificação de Requisição (CSRF)



O navegador confia no domínio e anexa o cookie automaticamente, mesmo que a ordem venha de um site invasor.

O Campo de Força: Flags de Segurança



HttpOnly

Visor Anti-XSS. Impede o acesso do JavaScript (cego para o document.cookie). Apenas o servidor manipula.

Secure

Túnel Criptografado. Instrui o navegador a trafegar o cookie estritamente via HTTPS (SSL/TLS).

SameSite: Strict

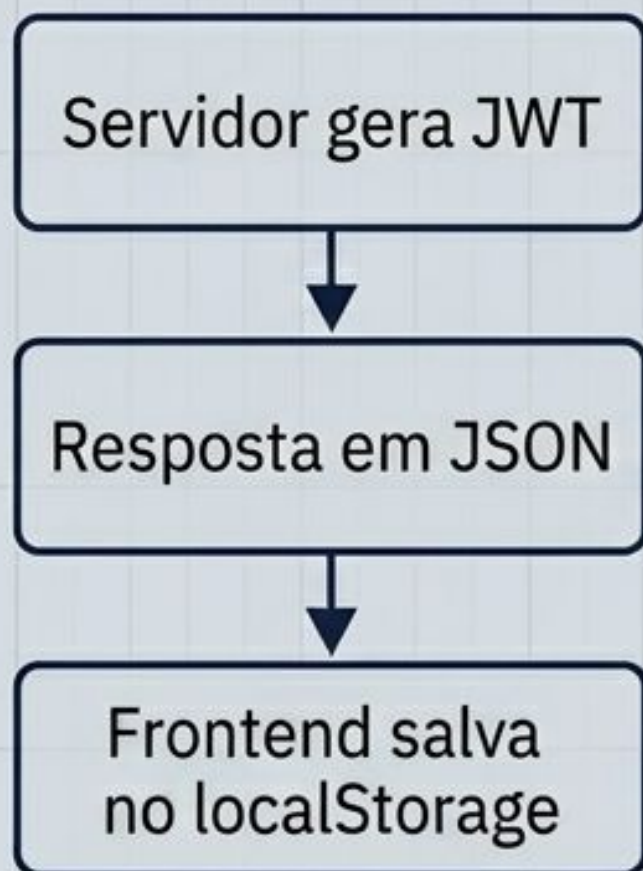
Corrente Antifurto. O cookie nunca sai do nosso domínio de origem, blindando o sistema contra CSRF.

* Referência de cabeçalhos de resposta HTTP.

Set-Cookie: PHPSESSID=k23r99pt87gl6m8p55m3of1ulh; path=/; HttpOnly; Secure; SameSite=Strict

0 Nosso Sistema: A Transição Arquitetural

Modelo Antigo (Vulnerável)



Risco Crítico: Vulnerável a XSS
(JavaScript tem controle total do token).

Novo Modelo (Blindado)



Ambiente Seguro: Navegador gerencia,
JavaScript fica completamente cego.

Mudar de localStorage para Cookies HttpOnly é o que separa sistemas amadores de sistemas preparados para o mercado real.

A Prova Definitiva: O Teste do Hacker



```
> localStorage.getItem('tokenUsuario')  
< null ✓  
  
> document.cookie  
< "" ✓  
  
>
```

The screenshot shows a browser's developer console with two log entries. The first entry shows the command `localStorage.getItem('tokenUsuario')` returning `null`, marked with a green checkmark. The second entry shows the command `document.cookie` returning an empty string `""`, also marked with a green checkmark. The console interface includes a 'Filter' input, 'top' dropdown, and 'Default levels' button.

O resultado: O JavaScript falha. A injeção XSS torna-se completamente inútil para roubar a sessão, pois o ambiente do DOM está cego para a existência do cookie.

A Prova Definitiva: A Aba Application

Name	Value	Domain	Path	Expires/ Max-Age	Size	HttpOnly	Secure	SameSite
token	eyJhbGciOi...	localhost	/	Session	120 B	✓		Strict
	eyJhbGciOi...							

A Prova Material: O token existe e é enviado ao servidor a cada clique, mas fica trancado na camada nativa do navegador. O sistema está perfeitamente preparado para o mercado real.

Resumo da Implementação (SOP)



Infraestrutura Backend

O middleware `cookie-parser` está devidamente instanciado no `server.js` antes das definições de rotas?



Higienização do Frontend

O sistema antigo (`localStorage.setItem` e `getItem` para tokens) foi completamente deletado dos scripts do lado do cliente?



Configuração do Cofre

O método de resposta `res.cookie` possui as flags de segurança `httpOnly` e `sameSite: 'Strict'` habilitadas por padrão?



Prontidão de Produção

A flag `Secure` está ativada (`true`) no ambiente de produção onde HTTPS/SSL está configurado?